

CAHIER DES CHARGES TECHNIQUE

Projet : Refonte du Système de Prise de Rendez-vous

Client : Hopital Regional

ESN	HealthBridge
Role	Analyste Technique
Version	1.0
Date	Juin 2026
Statut	Document de travail

Table des matieres

1.	Contexte et objectifs	3
2.	Perimetre fonctionnel	3
2.1	Prise de rendez-vous en ligne	3
2.2	Gestion des plannings	4
2.3	Gestion des salles et equipements	4
2.4	Notifications	4
2.5	Dossiers patients	5
3.	Architecture pressentie	5
4.	Stack technique recommandee	6
5.	Conformite RGPD sante	8
6.	Conformite RGAA	10

1. Contexte et objectifs

HealthBridge est mandatee par un hopital regional pour piloter la refonte complete de son systeme de prise de rendez-vous medicaux. Le systeme actuel est un logiciel desktop vieillissant, peu ergonomique, non accessible depuis l'exterieur et incompatible avec les exigences actuelles en matiere de protection des donnees de sante.

Objectifs du nouveau systeme :

- Permettre la prise de rendez-vous en ligne par les patients (24h/24, 7j/7)
- Offrir une gestion des plannings fluide pour les medecins et le secretariat
- Gerer les salles de consultation et les equipements medicaux
- Envoyer des rappels automatiques par email et SMS
- Assurer le suivi securise des dossiers patients (donnees de sante = RGPD renforce)
- Respecter les normes d'accessibilite RGAA et l'hebergement HDS

Le directeur general de l'hopital attend un cadrage technique complet avant de debloquer le budget. Aucun developpement applicatif complet n'est attendu a ce stade, mais des preuves de faisabilite technique sont requises (cf. POC).

2. Perimetre fonctionnel

2.1 Prise de rendez-vous en ligne

Le module de prise de rendez-vous constitue le coeur du systeme. Il doit etre accessible depuis tout navigateur moderne sans installation prealable.

- Recherche d'un medecin par specialite, nom ou disponibilite
- Visualisation des creneaux disponibles en temps reel
- Reservation d'un creneau avec confirmation instantanee
- Modification ou annulation d'un rendez-vous jusqu'a H-24
- Confirmation automatique par email et/ou SMS
- Historique des rendez-vous accessible dans l'espace patient

2.2 Gestion des plannings

Le secretariat et les medecins disposent d'interfaces dediees pour gerer leurs agendas respectifs.

- Agenda hebdomadaire et mensuel par medecin
- Creation et modification de creneaux de consultation
- Blocage de plages horaires (conges, formations, reunions)
- Vue globale du planning pour le secretariat
- Gestion des urgences et des rendez-vous hors ligne
- Export du planning (PDF, iCal)

2.3 Gestion des salles et equipements

L'hospital dispose de plusieurs salles de consultation et d'equipements partages (echographe, scanner portable, materiel de kinesitherapie...). Le systeme doit eviter les conflits de reservation.

- Inventaire des salles et equipements medicaux
- Affectation automatique d'une salle lors de la prise de RDV
- Reservation manuelle des equipements par le secretariat
- Alertes en cas de conflit de reservation
- Tableau de bord de disponibilite en temps reel

2.4 Notifications

Le systeme envoie des rappels automatiques pour reduire le taux d'absenteisme, estime a 15-20% sans rappel selon les etudes en milieu hospitalier.

- Rappel SMS et/ou email a J-1 du rendez-vous (configurable)
- Rappel a H-2 pour les rendez-vous du lendemain matin
- Notification de confirmation immediate apres reservation
- Notification d'annulation ou de modification
- Gestion des preferences de notification par patient
- Historique des notifications envoyes

2.5 Dossiers patients

Les données de santé sont des données sensibles au sens du RGPD (article 9). Leur accès est strictement contrôlé par des règles de confidentialité.

- Création et mise à jour du dossier patient par le secrétariat
- Accès aux informations médicales réservé aux médecins habilités
- Historique des consultations et comptes-rendus
- Téléchargement sécurisé des documents médicaux
- Journal d'audit de tous les accès (qui, quand, quelle donnée)
- Demande de suppression du dossier (droit à l'oubli)

3. Architecture pressentie

L'architecture retenue est une **application web SaaS** en architecture **3 tiers** (presentation / metier / donnees), hebergée sur un cloud certifié HDS. Ce choix est justifié par :

- Accessibilité universelle : aucune installation côté patient ou médecin
- Maintenabilité : mises à jour centralisées sans déploiement sur les postes
- Scalabilité : montée en charge facile via les services cloud
- Conformité : hébergement HDS natif chez les grands acteurs cloud français

Schema d'architecture

Couche	Composants	Role
Presentation	React 18 + TypeScript Tailwind CSS	Interface utilisateur responsive Accessible (RGAA)
API / Metier	NestJS (Node.js) Keycloak (Auth)	Logique métier Authentification OIDC/OAuth2
Donnees	PostgreSQL 16 Redis 7	Persistance ACID Cache sessions
Notifications	Twilio (SMS) SendGrid (email)	Rappels patients Confirmations RDV
Infrastructure	OVHcloud HDS Docker	Hébergement certifié HDS Conteneurisation

Flux de données principal :

```
Patient/Medecin (HTTPS) --> Frontend React (CDN / OVHcloud) --> API NestJS  
(authentifié via Keycloak) --> PostgreSQL (données chiffrées AES-256) -->  
Twilio/SendGrid (notifications)
```

Sécurité des flux : toutes les communications sont chiffrées en TLS 1.3. Les données de santé sont chiffrées au repos avec l'extension pgcrypto de PostgreSQL. Aucune donnée sensible ne transite en clair, y compris dans les logs.

4. Stack technique recommandee

La stack est choisie pour sa maturite, sa compatibilite avec les contraintes RGPD/HDS et sa facilite de recrutement dans l'ecosysteme francais.

Composant	Technologie	Version	Justification
Frontend	React + TypeScript	18 / 5.x	Composants reutilisables, typage fort, large ecosysteme, SSR possible (Next.js)
CSS	Tailwind CSS	3.x	Utilitaire, responsive by default, purge CSS automatique
Backend	NestJS (Node.js)	10.x	Architecture modulaire, injection de dependances, TypeScript natif
Base de donnees	PostgreSQL	16	ACID, maturite, pgcrypto pour le chiffrement des donnees de sante
Cache / Sessions	Redis	7.x	Sessions avec TTL, blacklist tokens revokes, performance
Authentification	Keycloak	24	SSO, OIDC/OAuth2, MFA, gestion des roles, open source
SMS	Twilio	latest API	Fiabilite, couverture France, API simple et bien documentee
Email	SendGrid	v3 API	Deliverabilite elevee, templates, tracking des ouvertures
Hebergement	OVHcloud	HDS certifie	Certification HDS, souverainete des donnees (France), RGPD natif
Conteneurisation	Docker Compose	latest	Portabilite, reproductibilite des environnements dev/prod
CI/CD	GitHub Actions	latest	Integration native GitHub, gratuit, large marketplace

Justification du choix web vs desktop

Le sujet laisse le choix entre une solution web ou desktop. La recommandation **web SaaS** se justifie par plusieurs arguments decisifs :

- **Accessibilite patient** : les patients peuvent prendre RDV depuis leur domicile, leur smartphone ou n'importe quel navigateur sans installation
- **Maintenance centralisee** : une seule codebase a maintenir, les mises a jour sont instantanees pour tous les utilisateurs
- **Conformite HDS facilitee** : l'hebergement centralise simplifie la certification et la gestion des sauvegardes
- **Cout total de possession** : pas de deploiement logiciel sur les postes, pas de gestion des versions cote client
- **Scalabilite** : le nombre d'utilisateurs simultanes peut etre ajuste dynamiquement selon la charge

Choix du SGBD : PostgreSQL

PostgreSQL est retenu face a MySQL/MariaDB et aux bases NoSQL pour les raisons suivantes :

- **ACID strict** : garantie d'integrite des donnees medicales, critique pour eviter les doubles reservations ou la corruption de dossiers
- **Extension pgcrypto** : chiffrement natif des colonnes sensibles (NSS, donnees medicales) sans surcout applicatif
- **Maturite** : 30 ans d'historique, documentation abondante, support commercial disponible
- **Conformite** : supporte les fonctionnalites necessaires a l'audit trail (triggers, logs)

5. Conformite RGPD sante

Les donnees traitees par MediPlan sont des **donnees de sante** au sens de l'article 9 du RGPD, soumises a des obligations renforcees. Leur traitement requiert une base legale specifique et des mesures de securite adaptees.

5.1 Classification des donnees traitees

Categorie	Exemples	Sensibilite	Base legale
Identite	Nom, prenom, date de naissance, NSS	Elevee	Art. 9.2.h RGPD (soins de sante)
Contact	Email, telephone, adresse	Moderee	Art. 6.1.b RGPD (execution du contrat)
Sante	Motif consultation, historique, CR medical	Tres elevee	Art. 9.2.h RGPD (soins de sante)
Connexion	Logs, adresses IP, sessions	Faible	Art. 6.1.f RGPD (interet legitime)
Consentement	Traces des accords marketing/notifications	Moderee	Art. 6.1.a RGPD (consentement)

5.2 Gestion du consentement

- **Consentement explicite** : recueil lors de l'inscription via une checkbox non pre-cochee, avec lien vers la politique de confidentialite
- **Consentement granulaire** : separement pour les soins, les rappels SMS et les rappels email
- **Tracabilite** : date, heure, version du document, canal de recueil stockes en base
- **Retrait** : possibilite de retirer le consentement a tout moment depuis l'espace patient, prise en compte dans les 72h

5.3 Droit a l'oubli (article 17 RGPD)

- Interface de demande de suppression accessible dans l'espace patient
- Traitement de la demande sous 30 jours maximum
- Suppression en cascade : donnees personnelles, historique RDV, fichiers associes
- **Exception legale** : les donnees de facturation sont conservees 10 ans (obligation comptable)
- Log de suppression maintenu a des fins d'audit (sans donnees personnelles)
- Confirmation par email de la suppression effective

5.4 Hebergement HDS (Hebergeur de Donnees de Sante)

Le decret n° 2018-137 du 26 fevrier 2018 impose l'hebergement des donnees de sante chez un **hebergeur certifie HDS**. Le choix retenu est **OVHcloud** pour les raisons suivantes :

- **Certification HDS** : certification active, auditee annuellement
- **Autres certifications** : ISO 27001, ISO 27017, ISO 27018, SOC 1 et SOC 2
- **Souverainete** : donnees hebergees exclusivement en France (regions GRA ou SBG)

- **Contrat** : contrat d'hébergement HDS obligatoire avec signature électronique
- **Sauvegarde** : sauvegardes chiffrées quotidiennes (AES-256), retention 30 jours

5.5 Mesures de sécurité techniques

Mesure	Implementation	Standard visé
Chiffrement en transit	TLS 1.3 obligatoire HTTPS uniquement	OWASP A02
Chiffrement au repos	pgcrypto (AES-256) pour données de santé	HDS / RGPD Art.32
Authentification forte	MFA obligatoire pour médecins et secrétariat	ANSSI RGS
Gestion des sessions	Expiration après 30 min d'inactivité, JWT + Redis	OWASP A07
Logs d'audit	Tous les accès aux données de santé tracés	HDS / Art.32 RGPD
Pseudonymisation	Données patients pseudonymisées dans les logs	RGPD Art.25
Contrôle des accès	RBAC via Keycloak (patient, médecin, secrétariat, admin)	OWASP A01

6. Conformite RGAA

Le RGAA (Referentiel General d'Amelioration de l'Accessibilite) v4.1 est applique conformement aux recommandations de la DINUM. Bien qu'une application hospitaliere privree ne soit pas legalement contrainte par le RGAA, son application garantit l'acces au service pour les patients en situation de handicap, un enjeu ethique et medical majeur. Les trois criteres prioritaires suivants sont appliques :

Critere 1.1 — Alternatives textuelles pour les images (Niveau A)

Regle RGAA : Toute image porteuse d'information doit avoir une alternative textuelle. Les images decoratives doivent avoir un attribut alt vide.

Application dans MediPlan :

- Les icones de statut de RDV (confirme, annule, en attente) ont des attributs alt descriptifs
- Les logos et illustrations medicales ont des descriptions contextuelles
- Les images purement decoratives ont un attribut alt vide (alt="")
- Les graphiques (tableaux de disponibilite) ont une alternative textuelle ou un tableau de donnees equivalent

Exemple d'implementation :

```
<!-- Icone porteuse d'information -->  <!-- Image decorative --> 
```

Critere 3.2 — Contraste des couleurs (Niveau AA)

Regle RGAA : Le rapport de contraste entre la couleur du texte et son arriere-plan doit etre d'au moins 4,5:1 pour le texte normal et 3:1 pour le grand texte (superieur a 18px ou 14px en gras).

Palette de couleurs validee (outil : WebAIM Contrast Checker) :

Usage	Couleur texte	Fond	Ratio	Conformite
Texte principal	#1E293B	#FFFFFF	16,1:1	AAA
Texte secondaire	#475569	#FFFFFF	7,0:1	AA + AAA
Bouton primaire	#FFFFFF	#1D4ED8	7,2:1	AA + AAA
Texte d'erreur	#DC2626	#FFFFFF	5,9:1	AA
Texte de succes	#059669	#FFFFFF	4,6:1	AA
Placeholder formulaire	#94A3B8	#FFFFFF	2,5:1	Non applicable*

* Les placeholders ne sont pas consideres comme du texte informatif (RGAA critere 11.9)

Critere 11.1 — Labels sur les formulaires (Niveau A)

Regle RGAA : Chaque champ de formulaire doit avoir un label associe. Les lecteurs d'ecran doivent pouvoir annoncer le nom du champ a l'utilisateur.

Application dans MediPlan :

- Tous les champs de prise de RDV ont un element label explicitement associe via l'attribut for
- Les messages d'erreur sont lies au champ concerne via aria-describedby
- Les champs obligatoires sont indiques visuellement ET via aria-required='true'
- Aucun placeholder n'est utilise comme seul label
- Les groupes de champs sont encapsules dans des fieldset avec une legend

Exemple d'implementation :

```
<div role="group" aria-labelledby="group-rdv"> <h3 id="group-rdv">Informations du rendez-vous</h3> <label for="date-rdv"> Date du rendez-vous <span aria-hidden="true">*</span> </label> <input id="date-rdv" type="date" aria-required="true" aria-describedby="date-rdv-error" /> <span id="date-rdv-error" role="alert" class="error"> Veuillez selectionner une date valide </span> </div>
```

Demarche globale RGAA : Au-dela de ces trois criteres, la demarche d'accessibilite sera integree des la phase de maquettage (Figma avec annotations d'accessibilite), maintenue lors du developpement (tests avec NVDA/VoiceOver) et verifiee avant la mise en production (audit RGAA partiel par l'equipe).

7. Sources consultées

Les references suivantes ont ete consultees pour l'elaboration de ce cahier des charges, notamment pour les sections relatives a la conformite RGPD, a l'hebergement HDS et a l'accessibilite RGAA.

RGPD et protection des donnees de sante

Reference	URL / Source
RGPD - Texte officiel (EUR-Lex)	eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32016R0679
CNIL - Donnees de sante	cnil.fr/fr/donnees-de-sante
CNIL - Outil PIA (AIPD)	cnil.fr/fr/outil-pia-logiciel-de-la-cnil
CNIL - Droit a l'effacement	cnil.fr/fr/le-droit-leffacement
Decret n.2018-137 - Hebergement donnees de sante	legifrance.gouv.fr/loda/id/JORFTEXT000036647524
ANS - Certification HDS : guide pratique	esante.gouv.fr/produits-services/hds
OVHcloud - Certification HDS et conformite RGPD	ovhcloud.com/fr/entreprise/certification-conformite/hds/

Accessibilite RGAA et WCAG

Reference	URL / Source
RGAA v4.1 - Criteres et tests (DINUM)	accessibilite.numerique.gouv.fr/methode/criteres-et-tests/
DINUM - Guide de mise en oeuvre du RGAA	accessibilite.numerique.gouv.fr/obligations/mise-en-oeuvre/
WCAG 2.1 - Web Content Accessibility Guidelines (W3C)	www.w3.org/TR/WCAG21/
WebAIM - Contrast Checker	webaim.org/resources/contrastchecker/
MDN Web Docs - ARIA	developer.mozilla.org/fr/docs/Web/Accessibility/ARIA
W3C WAI - Tutoriel formulaires accessibles	w3.org/WAI/tutorials/forms/

Architecture et securite

Reference	URL / Source
OWASP Top 10 - Risques de securite des applications web	owasp.org/www-project-top-ten/
ANSSI - Recommandations sur l'authentification multifacteur	ssi.gouv.fr/guide/recommandations-relatives-a-lauthentification-multifacteur
Keycloak - Documentation officielle (OIDC, OAuth2, OpenID Connect)	keycloak.org/documentation
NestJS - Documentation officielle	docs.nestjs.com
PostgreSQL - Documentation pgcrypto	postgresql.org/docs/current/pgcrypto.html